Name - Shubham R. Patil
Roll no - 44010426066

12/10/26

classmate
Date
Page

* Case Study : Security the university examination System.

A university users an Operating System - based examination management system to store student, records, exam marks, faculty details, and question papers. The System has three main user groups : Students, faculty, and administration. Students should be able to view only their own marks and download permitted learning materials. faculty members need to view student records and enter or modify marks. Administrators manage user accounts, permissions, and system configuration.

The university has assigned permissions through roles, but an audit review identifies the following events:

- At 10.00, the account Student07 has three failed login attempts.
- At 10.03, Student 07 successfully log in.
- At 10.04, Student07 attempts to open ExamMarks.xlsx, which contains marks for an entire class.
- At 10.05, the system records an attempted modification of ExamMarks.xlsx by Student07
- At 10.15 Faculty02 modifies marks in ExamMark.xlsx and saves the file successfully.
- At 10.20, an administrator discovers that a former faculty member's account is still alive.

- The audit log is stored on the same server, and users with broad permissions may be able to modify or delete it.

The University wants to protect confidentiality, integrity and availability; prevent unauthorized access, maintain accountability, and investigate suspicious activity. You are asked to recommend appropriate operating system access-control, security-administration, and auditing measures.

Questions :-

Q1 Identify the main security problems in the case study. List at least four risks or weaknesses indicated by the scenario.

Q2 Explain the differences between authentication and authorization using Student07 as an example. Distinguish identity verification from permission checking.

Q3 Recommend an access-control policy for students, Faculty and Administrators, Justify your choice. Consider how permissions should be assigned & managed.

Q4 Prepare a ~~Student~~ suitable Access Control list (ACL) for ExamMarks.xlsx

Specify appriate Read, write, and Delete permissions for each user group.

Q5 Explain how the principle of least Privileage should be applied in this System

State what each group need to do and which unnecessary permission should be removed.

Q6 Interpret the audit events from 10.00 to 10.05. What should the security team do next?

Explain why the sequence is suspicious without assuming that it proves an attack.

Q7 Identify at least five events that should be recorded in the audit logs.
Induce login, file, account, permission, and/or administraive events.

Q8 Explain why the audit logs must be protected & recommend two ways to protect them.
Consider unauthorized modification, deletion & investigation.

Q9 What action should be taken regarding the former faculty member's active account? Explain.

Relate your answer to account management & access control.

Q10 Suggest a practical incident - response & corrective-actio plan for the university.
Include investigation, access review, policy changes & follow up monitoring.

* Answers :-

Q1] => 1] Student 07 makes three failed login attempts, which may indicate a password-related problem or possible unauthorized login attempt.
2] Student 07 successfully logs in and then attempts to access ExamMarks.xlsx, which contains marks for all students.
3] Student 07 attempts to modify the marks file even though students should not have permission to change marks.
4] A former faculty member's account is still active which may allow unauthorized access to university resources.

Q2 => 1] Authentication (Identity Verification)
Authentication is the process of verifying the identity of a user. It checks whether the person is really who they claim to be.
Eg - At 10.03, Student 07 successfully logs in by entering the correct username & password. The system verifies Student07's identity & allows login.

2] Authorization (Permission Checking)
Authorization is the process of checking what an authenticated user is allowed to access or do.
Eg :- After logging in, Student 07 attempts to open ExamMarks.xlsx, which contains the marks of the entire class. The system should deny access because students are not authorized to view or modify this file.

Q3 => The university should use Role - Based Access Control (RBAC), in which permissions are Assigned according to the user's role.

- Students : Can view their own marks and download permitted learning materials.
- Faculty : Can view student records and enter or modify marks for their assigned subjects.
- Administrators : Can Manage user accounts, permissions and System Configuration.

RBAC is suitable because it makes access management easier and prevents users from accessing information or performing actions beyond their responsibilities. Permissions should be reviewed regularly

⇒Q4 An access Control list (ACL) specifies which users or groups can read, write, or delete a particular file.

The following ACL is recommended for ExamMarks.xlsx

User group	Read	Write	Delete
Students	No	No	No
Faculty (authorized)	yes	yes	No
Administrators	yes	Limited	No
Unauthorized user	No	No	No

The university should also maintain backups and record every authorized change to the marks file.

Q5⇒ The principle of least privileage means that every user should receive only the minimum permissions necessary to perform their duties. It helps prevent unauthorized access and protects confidential university examination data.

1] Students

- Need :- Permission to view their own marks & download permitted learning material.
- Remove :- Permission to modify or delete exam marks, access other student's records, and manage user Accounts.

2] Faculty members :-

- Need :- Permission to view student records and enter or modify marks for their assigned classes.
- Remove :- Permission to modify marks for other classes, delete examination records, manage admin accounts, and change system configuration.

3] Administrators :-

- Need :- Permission to create and disable user account, assign roles, manage permissions, & configure system.
- Remove : Unnecessary access to modify exam marks and permissions to modify or delete audit logs. Administrative access should be limited to actual job requirement.

Q6=> The audit events from 10.00 to 10.05 show suspicious activities involving Student07 and confidential exam-marks file.

1] Interpretation of audit events :

- 10.00 - Three failed login attempts :
  This may indicate an incorrect password or an attempt to guess the password.
- 10.03 - Successful login : Student07 successfully logsin after failed attempt.
- 10.04 - attempt to open :-
  Exam Marks.xlsx : Student07 attempts to access a file containing marks for the entire class, which student should not be allowed to access.

- 10.05 - Attempted modification: Student 07 attempts to modify the examination marks file, raising concerns about unauthorized changes.

* What should security team do next?

1] Check the audit logs, login history, IP address and device details to verify the activity
2] Check wheather Student 07 successfully accessed or modified the file
3] Temporarily restrict the account if Suspicious activity continous or acc compromise is Suspected
4] Preserve the audit log and investigate wheather any Confidential data was changed or disclosed.

The faculty member's successfully marks update at 10.15 should also be cheared against their assigned permissions. The former faculty member's active acc should be investigated Separately.

Q7 ⇒ The System should record :

- Successful and failed login attempts.
- Attempts to open or access files.
- Changes to student marks.
- Creation, modification, or deletion of user accounts.
- Changes to roles and access permissions.
- Administrative and System - Configuration changes.

These records help the university identify suspicious activities and investigate security incidents.

Q8 ⇒ Audit must be protected because they provide evidence of user activities and security incidents. If someone modifies or deletes the logs, the University may lose important evidence during an Investigation.

Two ways to protect them are :-

- Restrict access : Only authorized security personnel should be able to manage the logs.

- Use tamper-resistant storage : Store logs on a Separate, protected server and use mechanisms that detect unauthorized changes.

These measures helps maintain the accuracy & realiability of audit records.

Q9 ⇒ The university should immediately disable the former faculty member's account and revoke their access to university systems. It should also terminate active sessions, review the account's previous activities, and remove any unnecessary permissions.

This is important because former faculty members no longer require access to university resources. Disabling inactive accounts reduces the risk of unauthorized access & data misuse.

Q10 ⇒
- Investigate :- Review the audit logs, verify Student activities, and check wheather any marks were changed without authorization.
- Review access :- Disable the former faculty member account and examine the permissions of students, faculty and administrators.
- Improve security :- Apply RBAC and the Principle of least Privileage, enforce strong passwords, and enable multi-factor authentication where possible.
- Monitor regularly :- Protect audit logs, review suspicious activities, conduct periodic access reviews, and verify that corrective measures are effective.

These steps will help protect Confidential student records, prevent unauthorized changes, and improve the overall security of the university's operating system.